

Plan de respuesta ante incidentes de seguridad

Plantilla editable con el playbook para responder ante incidentes de seguridad en [empresa]: quién, cómo y cuándo.

1. Qué es un incidente

Cualquier evento que comprometa la confidencialidad, integridad o disponibilidad de los sistemas o datos: phishing ejecutado, ransomware, robo de equipo, filtración, cuenta comprometida o DDoS.

2. Clasificación y tiempos

Severidad	Ejemplo	Tiempo de respuesta
Bajo	Correo phishing reportado a tiempo	24 h
Medio	Cuenta comprometida aislada	4 h
Alto	Ransomware en un equipo	1 h
Crítico	Cifrado masivo o filtración	Inmediato

3. Fases de respuesta

Detección

- Vías: reporte de empleados, alertas de monitorización, aviso de terceros.
- Registrar fecha, hora y evidencia de cada incidente.

Contención

- Aislar el equipo afectado de la red (desconectar cable/wifi, no apagar).
- Suspender cuentas comprometidas y revocar sesiones activas.
- Bloquear C2/dominios maliciosos en el firewall si aplica.

Erradicación y recuperación

- Identificar la causa raíz (cómo entró).
- Limpiar el sistema o restaurar desde backup verificado.
- Cambiar contraseñas y claves afectadas.
- Restaurar los servicios en orden de prioridad del DRP.

Post-incidente

- Informe de incidente: cronología, causa, impacto, acciones.
- Notificación a la AEPD en < 72 h si hay riesgo para los interesados (RGPD).
- Lecciones aprendidas y mejora de controles.

4. Contactos de emergencia

Contacto	Teléfono / Email
Responsable TI	
Proveedor de ciberseguridad (Forj)	
AEPD (notificación de brechas)	https://www.aepd.es
INCIBE (soporte pymes)	017
Seguro cibernético (si existe)	